



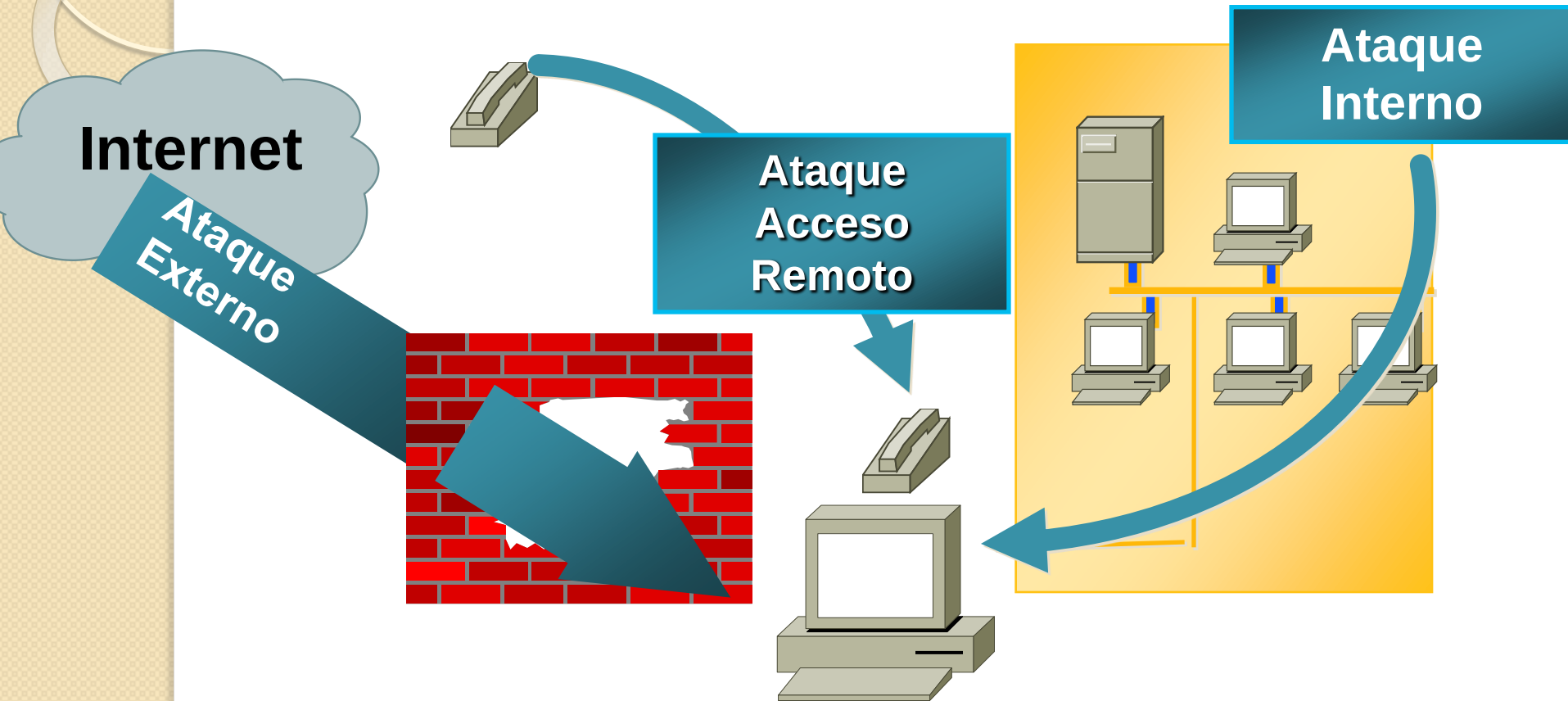
Seguridad en Redes

Ing. Gabriel Filippa

Seguridad en la comunicación

- Tipos de ataques y política de seguridad
- Protección del acceso a las redes internas, a través de firewalls y otras herramientas.

Quienes nos atacan???



De todos lados nos atacan!!.. Siempre nos preocupamos por los externos, pero lo ataques internos son normalmente mas graves, ya que tienen mas información para poder hacer daño.

Seguridad externa

- Nos enfocamos en la seguridad externa, para ellos veremos:
 - Firewalls
 - Proxys
 - NAT/PAT
 - Control de accesos
 - Cifrado.

Gestión de la seguridad



Tendencias de la seguridad

*la concentración de la seguridad en un punto, obligando a todo el tráfico entrante y saliente pase por un mismo punto, que normalmente se conoce como **cortafuegos o firewall**, permitiendo concentrar todos los esfuerzos en el control de tráfico a su paso por dicho punto”*

Firewalls o cortafuego

Consiste en un dispositivo formado por uno o varios equipos que se sitúan entre la red de la empresa y la red exterior (*normalmente la Internet*), que **analiza todos los paquetes que transitan entre ambas redes y filtra** los que no deben ser reenviados, de acuerdo con un **criterio establecido de antemano**, de forma simple.

Para que no se convierta en cuello de botella en la red, deben de procesar los paquetes a una **velocidad** igual o superior al router.

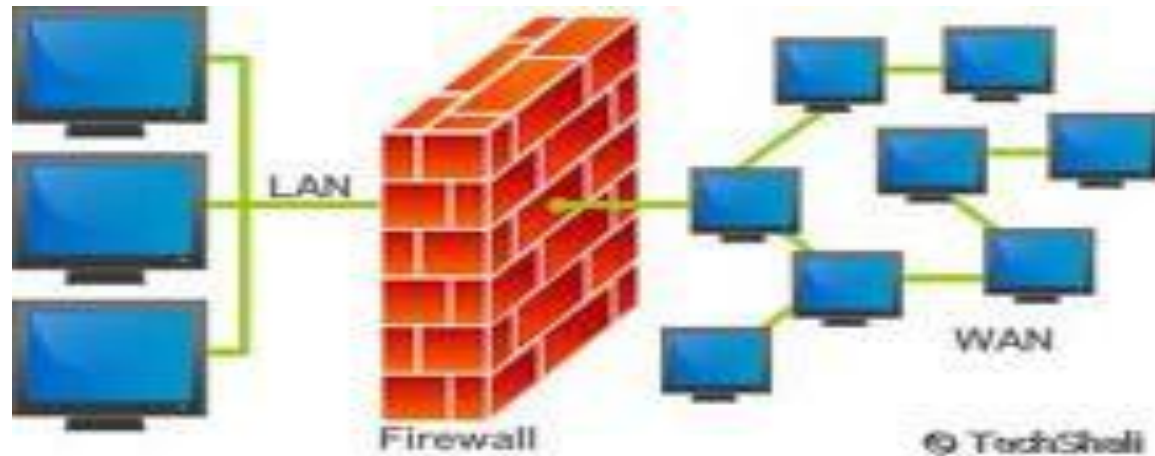
Firewalls o cortafuego

Crea un perímetro de defensa y seguridad alrededor de la red a proteger.

Se debe configurar de acuerdo a los servicios que brinde la red (WWW, FTP, Telnet, e-mail, etc.), así como conexiones entrantes a la red.

El firewall opera como un proxy y como un NAT.

Firewalls o cortafuego



El firewall realiza filtrado de paquetes:

- A nivel de red, con direcciones IP y la interfaz que llega el paquete, generalmente a través de lista de accesos.
- a nivel de transporte, con los puertos y tipo de accesos .
- a nivel de aplicación, con los datos a través de pasarelas para las aplicaciones permitidas analizando el contenido de los paquetes y los protocolos de aplicación (ejemplo servidor proxy).

Algunas configuraciones de firewalls

1.- un router separando la red Intranet de Internet, también conocido como *Screened Host Firewall*, que puede enviar el tráfico de entrada sólo al *host bastión*

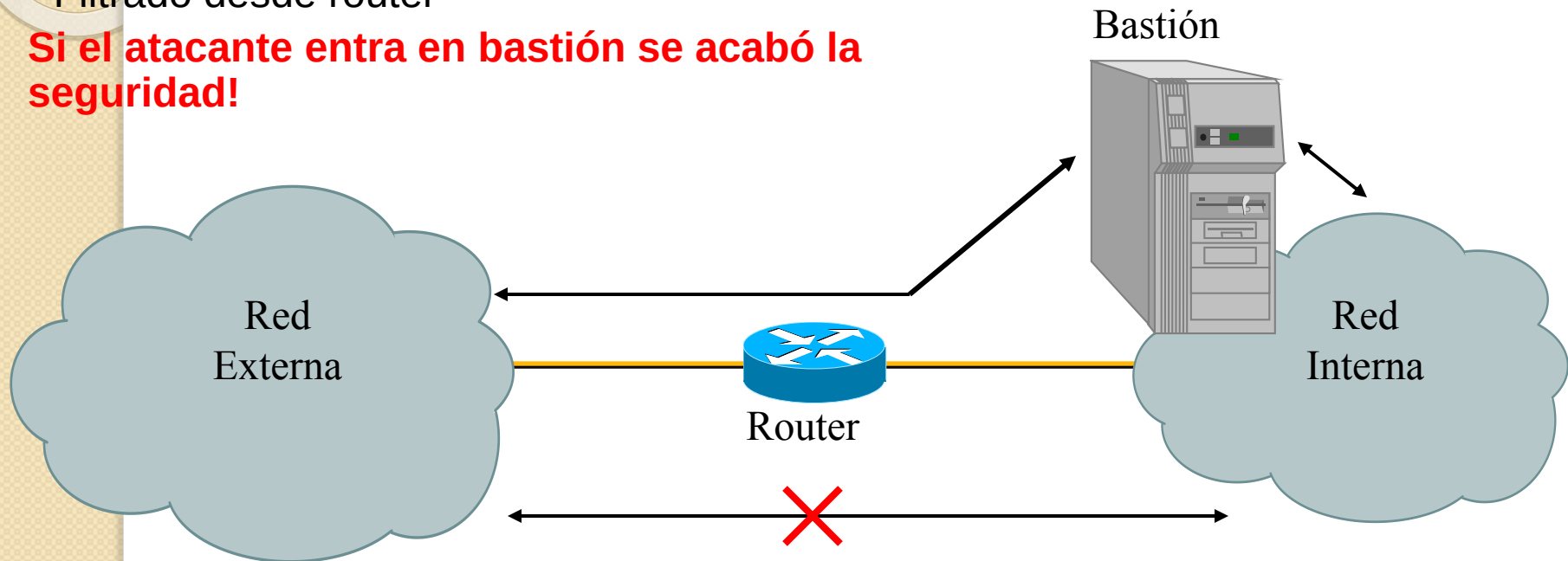
2.- un host bastión o pasarela para las aplicaciones permitidas separando la red Intranet de Internet, también conocido como *Dual Homed Gateway*

3.- con dos routers separando la red Intranet e Internet y con el host bastión dentro de la red formada por ambos routers, también conocida como *Screened Subnet*, esta red interna es conocida como zona neutra de seguridad o zona desmilitarizada (*DMZ Demilitarized Zone*)

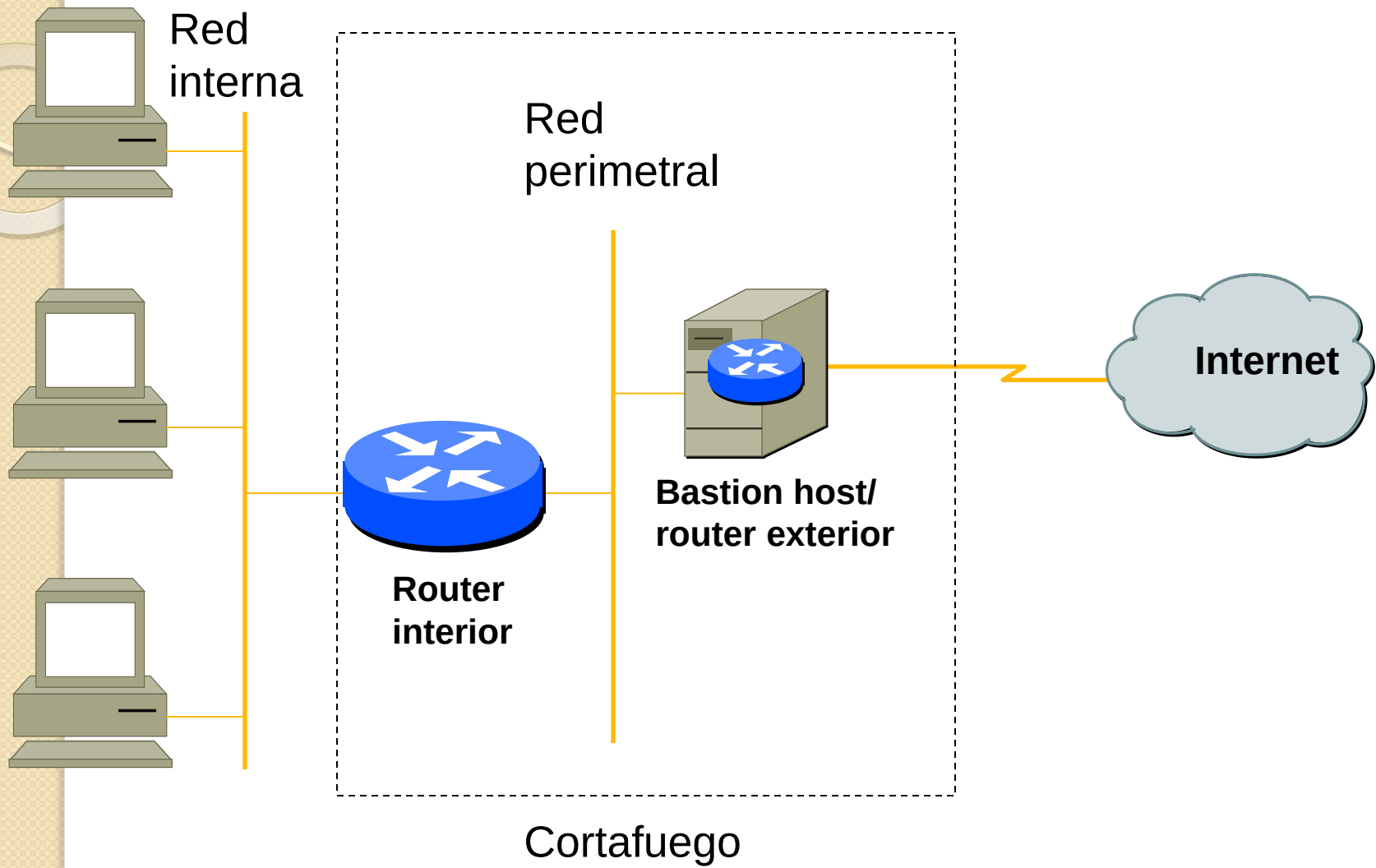
Screened host

- Router bloquea todo el tráfico hacia la red interna, excepto al bastión
- Servicios vía proxy desde el bastión
- Filtrado desde router

Si el atacante entra en bastión se acabó la seguridad!



Esta arquitectura permite mantener la conectividad transparente cuando esté justificado, obligando a pasar por el 'bastion host' el resto



Dual-homed gateway

Un host (*bastión*) con dos tarjetas de red, conectadas a redes diferentes

En esta configuración, el **bastión puede filtrar hasta capa de aplicación.**

Son sistemas muy baratos y fáciles de implementar

Sólo soportan servicios mediante proxy

El filtrado de paquetes, puede realizarse en *Linux* a través de “*iptables*”

Screened subnet

Se sitúa una red DMZ (*DeMilitarized Zone*) entre la interna y la externa, usando dos routers y que contiene el bastión

Tráfico sospechoso se envía hacia el bastión, si no puede pasar directamente.

Soporta servicios mediante proxy (bastión)

Soporta filtrado de paquetes (routers)

Es complicada y cara de implementar

Si el atacante entra en el bastión, todavía tiene un router por delante (no puede hacer sniffing)

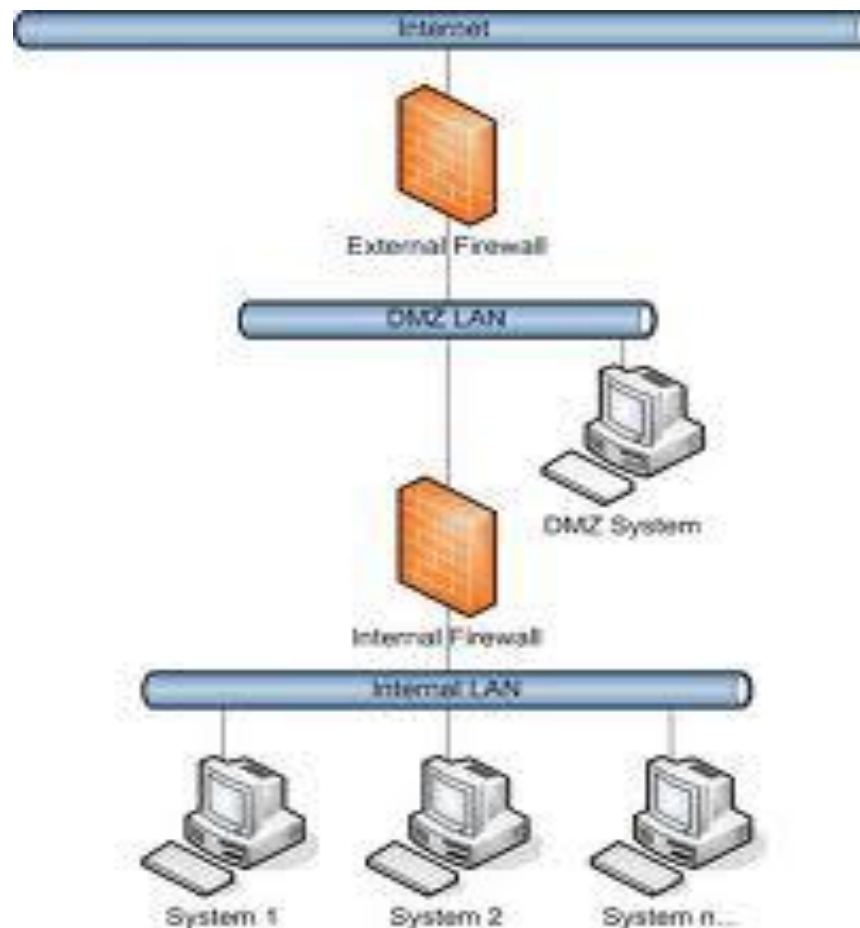
Screened subnet

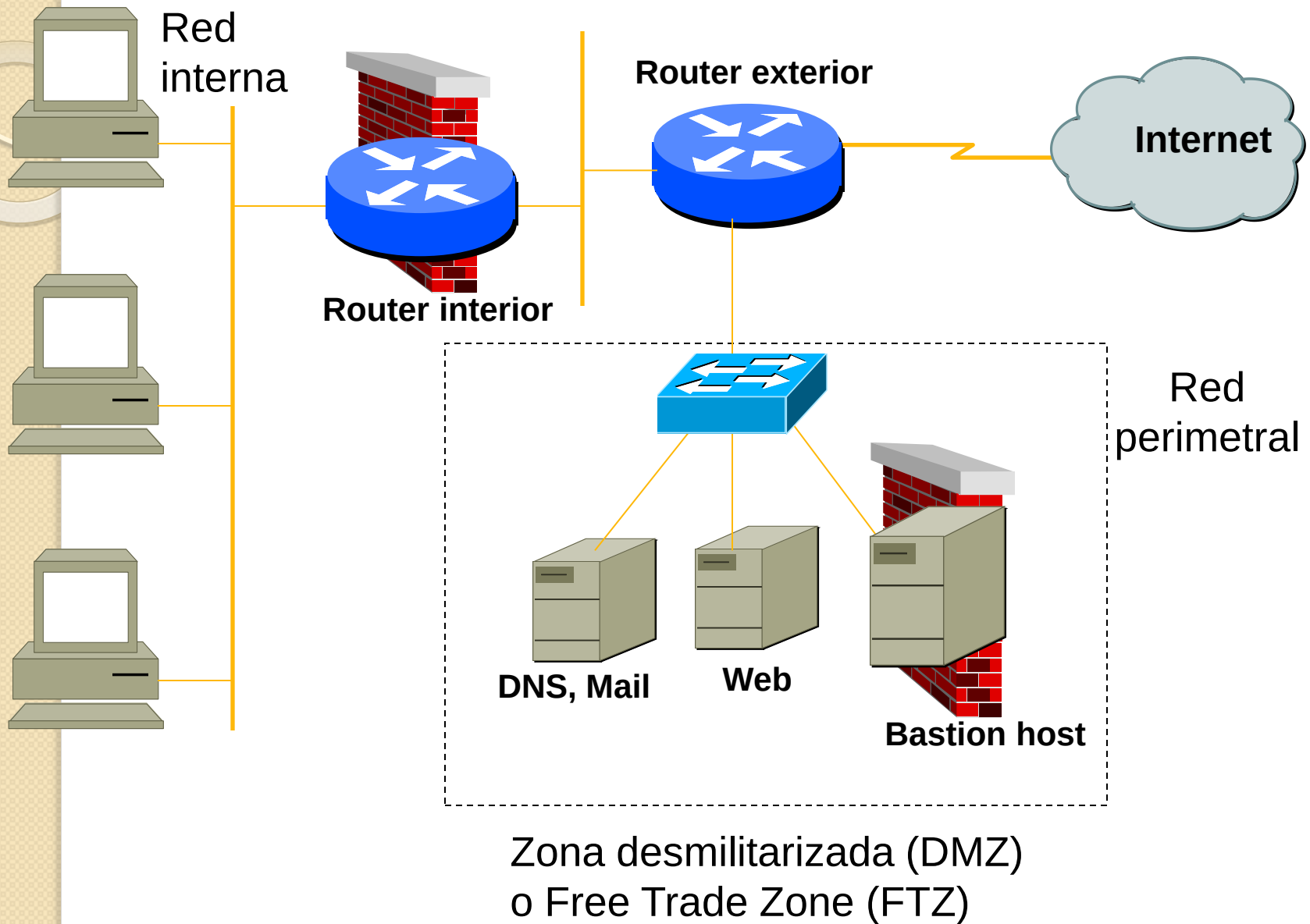
Configuración: consistente en implementar un perímetro con 2 routers y un host bastión. Es la arquitectura más segura y tiene las ventajas:

en ningún momento el exterior puede saturar la red interna, ya que están separadas

en ningún momento se puede monitorizar (sniffer) la red interna en el caso de que el host bastión fuera sabotado

Configuración de DMZ





Preparación del router

- Definir la *access list* para redirigir el tráfico externo al bastión
- Rechazar los mensajes externos con dirección interna (*anti-spoofing*)
- Deshabilitar la respuesta a los mensajes “*ICMP redirect*”
- Quitar el soporte de acceso por telnet (*al menos externamente*) y WEB.
- Separar tráfico de gestión y de servicio, mediante asignación de diferentes direcciones, o diferente localización

Detección de intrusos: IDS

Las vulnerabilidades de los diferentes sistemas dentro de una red son los caminos para realizar los ataques.

En muchas ocasiones, el atacante **enmascara** el ataque en tráfico permitido por el *cortafuegos* y por tanto para delatarlo se necesita un **IDS**. Son complementarios.

Características deseables para un IDS son:

- continuamente en ejecución y debe poderse analizar él mismo y detectar si ha sido modificado por un atacante
- utilizar los mínimos recursos posibles
- debe de adaptarse fácilmente a los cambios de sistemas y usuarios, ***por lo que en ocasiones poseen inteligencia para adaptarse (aprender por su experiencia) y configurarse.***

Tipos de IDS

- NIDS: (*NetworkIDS*): un IDS basado en red, detectando ataques a todo el segmento de la red. Su interfaz debe funcionar en modo promiscuo capturando así todo el tráfico de la red.
- HIDS: (*HostIDS*): el principio de funcionamiento de un HIDS, depende del éxito de los intrusos, que generalmente dejen rastros de sus actividades en el equipo atacado, cuando intentan adueñarse del mismo, con propósito de llevar a cabo otras actividades. El HIDS intenta detectar tales modificaciones en el equipo afectado, y hacer un reporte de sus conclusiones.

Sistemas pasivos y sistemas reactivos

- En un sistema pasivo, el sensor detecta una posible intrusión, almacena la información y manda una señal de alerta que se almacena en una base de datos.
- En un sistema reactivo, el IDS responde a la actividad sospechosa reprogramando el cortafuegos para que bloquee tráfico que proviene de la red del atacante. Un sistema que reacciona ante el ataque previniendo que este continúe, se denomina IPS por sus siglas en inglés de "Intrusion prevention system".

Jarrón de miel (*HONEY POT*)

En ocasiones es interesante aprender de los propios atacantes.

Para ello, en las redes se ubican **servidores** puestos adrede para que los intrusos los saboteen y son monitorizados por sistemas que actúan como **puentes** a los servidores, registrando de forma transparente los paquetes que acceden a dichos servidores.

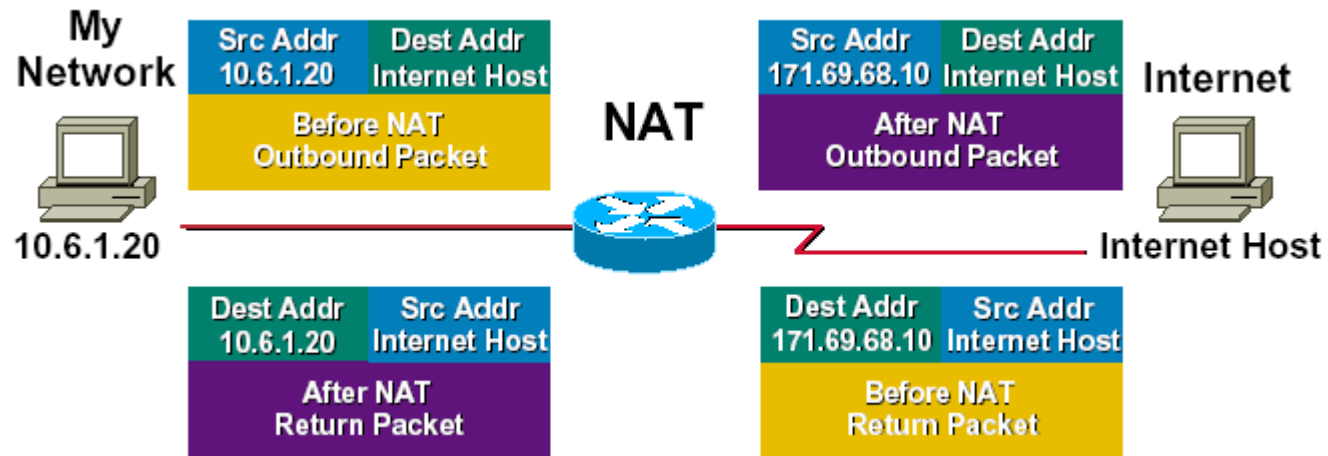
Detectado un ataque (*por modificación de la estructura de archivos*), se recompone la traza del atacante (*secuencia de paquetes registrados en el monitor puente*) y se pasa a un **análisis forense**.

Este análisis forense concluye, en caso de detectar un nuevo ataque, en **una nueva regla de detección**.

NAT y PAT

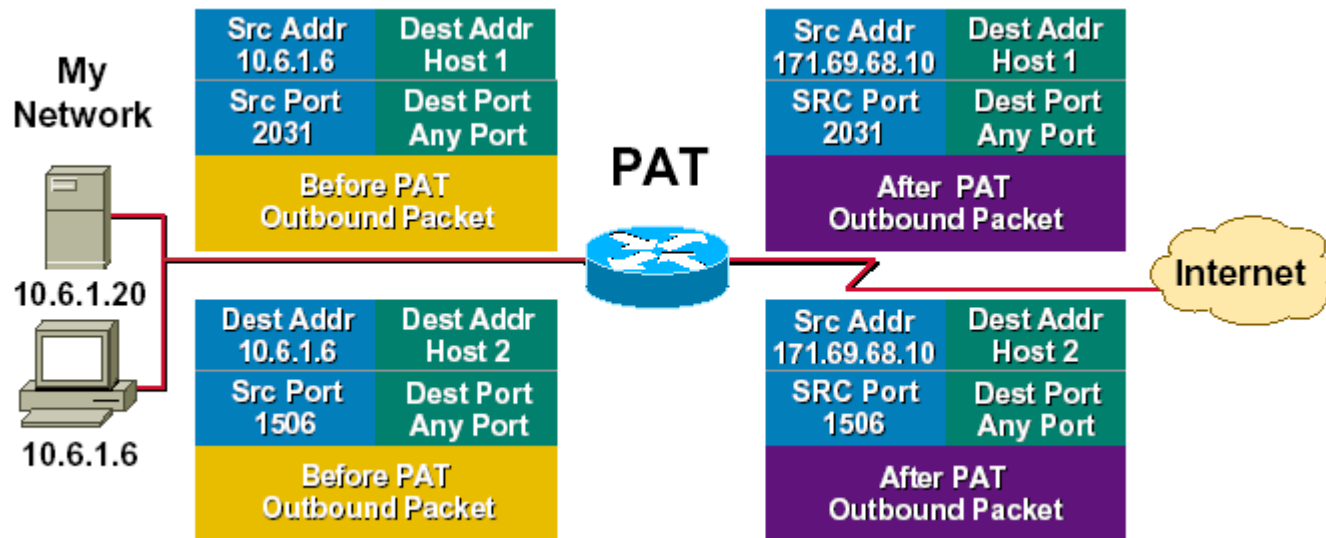
- Concepto básico de
 - Network Address Translation (NAT)
 - Port Address Translation (PAT)
- Conceptos y Terminología de NAT
- Port Address Translation (PAT)

Concepto básico de NAT



La Traducción de Direcciones de Red (NAT) cambia las direcciones IP en el encabezado IP.

Concepto básico de PAT



- La Traducción de Direcciones de Puertos (PAT) extiende a NAT de “uno a uno” a “varios a uno” asociando el puerto origen con cada flujo.

Definición de NAT

- Descrito en el RFC 1631
- Problema: El espacio de direccionamiento IP está limitado y el obtener un bloque de direcciones registradas es difícil.
- Solución: Utilizar direcciones IP privadas (RFC 1918) en la red interna.
- Las direcciones IP privadas que se pueden utilizar para la red interna son:
 - Clase A: 10.x.x.x
 - Clase B rango: 172.16.x.x–172.31.x.x
 - Clase C rango: 192.168.1.x–192.168.254.x

Beneficios de NAT

- NAT reemplaza la dirección origen con una dirección ruteable permitiendo a hosts con direcciones privadas acceder a internet.
- NAT provee de conectividad transparente, escalable y bidireccional entre distintas oficinas de la misma empresa.
- NAT elimina la necesidad de reasignar números a los hosts al cambiar de ISP o de esquemas de direccionamiento.
- NAT fortalece la privacidad de red puesto que las direcciones asignadas se encuentran ocultas. Evita el escaneo de puertos en la red.

PAT

- PAT (Port Address Translation). La traducción de direcciones de puerto incluye puertos además de las dir. IP.
 - Permite traducción de varios a uno.
 - Mapea múltiples dir. IP a una ó a unas cuantas.
 - Un número único de puerto origen identifica cada sesión.
 - También se le llama NAPT en los documentos de la IETF.
 - Utiliza un pool de dir. IP
 - Puede utilizar un nombre de interfaz.

NAT vs PAT

- NAT
 - Cuando hay suficiente número de dir. IP para traducciones 1 a 1.
- PAT
 - Cuando hay un número insuficiente de dir. IP disponibles para traducir todos las dir. Internas (inside addresses).